

Bezpečnosť elektronickej pošty – analýza hrozieb a návrh nástroja na detekciu podozrivých e-mailov

Alexander Ovšonka

Marec 2026

Úvod

Elektronická pošta patrí medzi najrozšírenejšie komunikačné služby internetu a zároveň predstavuje jeden z najčastejších smerov kybernetických útokov. Útočníci využívajú email najmä na šírenie phishingových kampaní, spamových správ, škodlivých príloh.

Cieľom projektu je analyzovať bezpečnostné hrozby elektronickej pošty a navrhnúť vlastný nástroj na detekciu podozrivých e-mailov. Navrhované riešenie bude využívať hybridný prístup kombinujúci heuristickú analýzu e-mailových hlavičiek a obsahu správy s klasifikačným modelom strojového učenia.

Vybrané oblasti témy

V rámci tejto teoretickej časti práce sme vybrali oblasti, ktoré poskytujú teoretický základ pre experimentálnu časť práce. Z tohto dôvodu sme teoretickú časť rozdelili na štyri sekcie:

Architektúra e-mailovej komunikácie: V tejto časti sa budeme venovať princípu fungovania e-mailovej komunikácie, úlohe e-mailových serverov v tomto procese a zároveň sa zameriame na jednotlivé e-mailové protokoly (napr. SMTP, POP3 alebo IMAP). Cieľom tejto časti je poskytnúť hlbšie pochopenie fungovania elektronickej pošty.

Formát e-mailovej správy: Táto časť sa bude venovať štruktúre samotnej e-mailovej správy, jej hlavičke, MIME formátu a spôsobu prenosu príloh a HTML obsahu.

Bezpečnostné hrozby e-mailovej komunikácie: V tejto teoretickej časti predstavíme základné bezpečnostné hrozby, s ktorými sa môžeme stretnúť pri e-mailovej komunikácii, ako napríklad spam, phishing, spear phishing, spoofing odosielateľa alebo distribúcia malvéru prostredníctvom e-mailu.

Mechanizmy ochrany elektronickej pošty: V poslednej teoretickej sekcii predstavíme rôzne mechanizmy určené na ochranu elektronickej pošty, ako sú SPF, DKIM a DMARC. Okrem toho sa budeme venovať aj heuristickej detekcii phishingu a klasifikácii e-mailov pomocou metód strojového učenia.

Analýza existujúcich nástrojov

V rámci tejto sekcie budú predstavené jednotlivé nástroje, ktoré budú využité v experimentálnej časti práce. Plánujeme použiť nasledujúce nástroje:

MailHog: Testovací SMTP server používaný na zachytávanie e-mailov v testovacom prostredí. Umožňuje jednoduché sledovanie prijatých správ a export e-mailov vo formáte vhodnom na ďalšiu analýzu.

GoPhish: určený na simuláciu phishingových kampaní. Umožňuje vytvárať testovacie phishingové e-maily a analyzovať ich správanie v kontrolovanom prostredí.

PhishTool: určený na analýzu phishingových e-mailov, ktorý pomáha identifikovať indikátory kompromitácie a analyzovať obsah správ.

Uvedené nástroje umožňujú vytvoriť kontrolované experimentálne prostredie pre generovanie a analýzu testovacích e-mailových správ.

Problémy, ktoré bude projekt analyzovať

Projekt sa zameria najmä na analýzu problémov spojených s identifikáciou podvodných alebo phishingových e-mailov. Nižšie sú uvedené hlavné problémy, ktorým sa budeme v rámci experimentálnej časti venovať.

Spoofing odosielateľa

Útočníci často falšujú adresu odosielateľa tak, aby sa e-mail tváril ako správa od dôveryhodnej organizácie. Projekt sa zameria na identifikáciu nesúladu medzi rôznymi hlavičkami správy, napríklad medzi poľami *From*, *Return-Path* alebo *Reply-To*.

Autentifikácia e-mailu

Projekt bude skúmať výsledky autentifikačných mechanizmov SPF, DKIM a DMARC a ich využitie pri identifikácii podozrivých e-mailov.

Analýza e-mailových hlavičiek

Hlavičky e-mailu obsahujú informácie o trase doručenia správy a autentifikačných kontrolách. Analýza týchto údajov môže odhaliť podozrivú infraštruktúru alebo manipuláciu so správou.

Analýza URL odkazov

Phishingové e-maily často obsahujú odkazy na podvodné webové stránky. Projekt bude analyzovať vlastnosti URL odkazov, napríklad:

- podobnosť domén,
- použitie IP adresy namiesto domény,
- použitie skracovačov odkazov,
- podozrivé znaky v názve domény.

Experimentálna časť

Návrh vlastného riešenia

V rámci projektu bude navrhnutý nástroj, ktorého cieľom bude analyzovať e-mailové správy a identifikovať potenciálne rizikové alebo podozrivé prvky.

Navrhovaný nástroj bude pozostávať z dvoch hlavných komponentov.

Prvý komponent bude založený na heuristickej analýze e-mailu. Tento modul bude využívať súbor pravidiel určených na identifikáciu typických znakov podvodných alebo podozrivých e-mailov. Na základe zistených indikátorov bude nástroj priradovať e-mailu určité rizikové skóre.

Druhý komponent bude využívať model strojového učenia, ktorý bude analyzovať text e-mailovej správy a odhadovať pravdepodobnosť, že ide o spamový alebo phishingový e-mail.

Výsledné hodnotenie e-mailu bude založené na kombinácii heuristickej analýzy a výsledku modelu strojového učenia, čím sa vytvorí celkové rizikové skóre správy.

Prostredie

Na účely testovania bude vytvorené kontrolované prostredie, ktorého cieľom bude simulovať základnú e-mailovú komunikáciu a umožniť generovanie testovacích e-mailových správ. V prostredí budú zapojené tri hlavné komponenty: testovací e-mailový server, nástroje na generovanie phishingových e-mailov a nami implementovaný nástroj na analýzu e-mailov.

Experimenty budú prebiehať na lokálnom počítači so systémom Windows s využitím technológie Docker.

Prostredie bude obsahovať tieto komponenty:

- **MailHog** – testovací SMTP server zachytávajúci e-mailové správy,
- **GoPhish** – nástroj na generovanie phishingových e-mailov,
- vlastný analyzačný nástroj implementovaný v jazyku Python.

V rámci experimentov budú testované rôzne typy e-mailov, napríklad:

- legítimne e-maily bez podozrivých prvkov,
- phishingové e-maily obsahujúce podozrivé odkazy,
- e-maily so spoofovaným odosielateľom,
- spamové e-maily.

Implementácia analyzačného nástroja

Navrhovaný nástroj na analýzu e-mailov bude implementovaný v programovacom jazyku Python. Jeho základnou funkcionalitou bude schopnosť načítať e-mail vo formáte `.eml`, následne analyzovať e-mailovú hlavičku, extrahovať URL odkazy z tela správy a identifikovať podozrivé vlastnosti e-mailu. Na základe týchto zistení bude nástroj vypočítavať rizikové skóre e-mailovej správy.

Súčasťou navrhnutého nástroja bude aj modul strojového učenia, ktorý bude analyzovať text e-mailovej správy a určovať pravdepodobnosť, že ide o spamový alebo phishingový e-mail.

Model bude trénovaný na verejne dostupnom datasete e-mailov (napríklad *Enron Spam Dataset*), ktorý obsahuje legítimne aj spamové správy. Pred samotným tréningom bude text e-mailov predspracovaný pomocou základných techník spracovania prirodzeného jazyka. Následne bude text transformovaný do numerickej reprezentácie, ktorá umožňuje zachytiť význam jednotlivých slov v e-mailoch.

Na klasifikáciu budú použité klasifikačné algoritmy strojového učenia. Model bude vyhodnotený pomocou štandardných metrík, ako sú *accuracy*, *precision*, *recall* a *F1-score*. Výsledná pravdepodobnosť, že ide o spamový alebo phishingový e-mail, bude následne kombinovaná s výsledkom heuristickej analýzy e-mailu, čím vznikne celkové rizikové skóre správy.

Experimenty

Experiment 1 – simulácia phishingových e-mailov

Prvým experimentom bude simulácia phishingových e-mailov pomocou nástroja *GoPhish*. Pomocou tohto nástroja budú vytvorené testovacie phishingové kampane obsahujúce rôzne typy podvodných správ, napríklad:

- e-maily vyžadujúce overenie účtu,
- e-maily obsahujúce podozrivé odkazy,
- e-maily imitujúce komunikáciu známej organizácie.

Tieto e-maily budú odoslané do testovacieho SMTP servera *MailHog*, ktorý zachytí všetky prijaté správy. Zachytené e-maily budú následne exportované vo formáte *.eml* a použité ako vstup pre náš nástroj.

Cieľom experimentu je overiť, či navrhnutý nástroj dokáže identifikovať základné indikátory phishingových správ, napríklad podozrivé odkazy alebo nesúlad medzi jednotlivými hlavičkami e-mailu.

Experiment 2 – analýza e-mailových hlavičiek

Druhý experiment bude zameraný na analýzu e-mailových hlavičiek a autentifikačných mechanizmov elektronickej pošty. V tomto experimente budú analyzované hlavičky zachytených e-mailov s cieľom identifikovať indikátory potenciálneho spoofingu alebo manipulácie so správou.

Analyzované budú najmä tieto prvky:

- výsledky autentifikačných kontrol SPF, DKIM a DMARC,
- nesúlad medzi poľami *From*, *Return-Path* a *Reply-To*,
- informácie o trase doručenia správy v hlavičkách *Received*.

Experiment 3 – detekcia phishingových indikátorov

Phishingové e-maily často obsahujú odkazy vedúce na podvodné webové stránky. V tomto experimente bude analyzovaný obsah e-mailov s cieľom identifikovať podozrivé URL odkazy.

Nástroj bude extrahovať odkazy z tela správy a analyzovať ich vlastnosti, napríklad:

- podobnosť domén s legitímnymi službami,
- použitie IP adresy namiesto doménového mena,
- prítomnosť skracovačov odkazov,
- neštandardné znaky alebo podozrivé názvy domén.

Experiment 4 – vyhodnotenie klasifikačného modelu

Experiment bude zameraný na vyhodnotenie klasifikačného modelu strojového učenia, ktorý bude analyzovať text e-mailových správ.

Model bude trénovaný na verejne dostupnom datase e-mailov obsahujúcom legitímne aj spamové správy. Po natrénovaní modelu bude jeho výkonnosť testovaná na samostatnej testovacej množine e-mailov.

Výsledky klasifikácie budú vyhodnotené pomocou nasledujúcich metrík:

- accuracy,
- precision,
- recall,
- F1-score.

Experiment 5 – porovnanie detekčných prístupov

Experimente budú porovnané tri rôzne prístupy detekcie podozrivých e-mailov:

- heuristická analýza e-mailu,
- klasifikácia pomocou strojového učenia,
- kombinácia oboch metód.

Cielom experimentu bude zistiť, či kombinácia heuristickej analýzy a klasifikačného modelu strojového učenia poskytuje presnejšie výsledky pri detekcii phishingových alebo spamových e-mailov v porovnaní s použitím jednotlivých metód samostatne.

Experiment 6 – porovnanie s nástrojom PhishTool

V tomto experimente bude porovnaný navrhnutý nástroj s existujúcim nástrojom PhishTool, ktorý je určený na analýzu phishingových e-mailov.

Pre rovnaký súbor testovacích e-mailov bude vykonaná analýza pomocou oboch nástrojov. Následne budú porovnané identifikované indikátory kompromitácie a schopnosť nástrojov detegovať podozrivé e-maily.

Časový plán

1. progress report

V prvej fáze projektu bude realizované štúdium problematiky bezpečnosti elektronickej pošty a analýza základných princípov fungovania e-mailovej komunikácie.

Analyzované budú:

- architektúra e-mailovej komunikácie,
- formát e-mailovej správy a e-mailové hlavičky,
- základné bezpečnostné hrozby e-mailovej komunikácie,
- mechanizmy autentifikácie e-mailov (SPF, DKIM, DMARC).

Výstupom tejto fázy bude teoretický prehľad problematiky a spresnenie návrhu projektu vrátane základnej architektúry navrhovaného nástroja.

2. progress report

V druhej fáze projektu bude realizovaná analýza existujúcich nástrojov používaných pri testovaní a analýze bezpečnosti e-mailovej komunikácie.

Analyzované budú najmä tieto nástroje:

- MailHog – testovací SMTP server,
- GoPhish – nástroj na simuláciu phishingových kampaní,
- PhishTool – nástroj na analýzu phishingových e-mailov.

V tejto fáze bude zároveň zdôvodnený výber nástrojov použitých v experimentoch a bude navrhnutá architektúra experimentálneho prostredia.

3. progress report

V tretej fáze projektu bude vytvorené experimentálne prostredie a realizovaná implementácia základných častí navrhovaného nástroja.

Implementované budú:

- heuristický analyzátor e-mailových hlavičiek,
- modul na extrakciu a analýzu URL odkazov,
- základná implementácia klasifikačného modelu strojového učenia.

Zároveň bude predstavená konfigurácia experimentálneho prostredia a budú prezentované prvé predbežné výsledky analýzy testovacích e-mailov.

4. progress report

V poslednej fáze projektu budú realizované experimenty zamerané na vyhodnotenie navrhnutého nástroja.

Výsledky experimentov budú následne analyzované a porovnané s cieľom zhodnotiť efektivitu navrhnutého riešenia.

Zoznam literatúry

1. MailHog – Email testing tool. Dostupné na: <https://github.com/mailhog/MailHog>
2. GoPhish – Open-source phishing framework. Dostupné na: <https://getgophish.com/>

3. PhishTool – Phishing analysis platform. Dostupné na: <https://www.phishtool.com/>
4. Internet Engineering Task Force (IETF). RFC Datatracker – Internet Standards Documentation. Dostupné na: <https://datatracker.ietf.org/>
5. IEEE Xplore. Machine Learning Based Phishing Email Detection. Dostupné na: <https://ieeexplore.ieee.org/document/9666627>
6. Hybrid Heuristic-Machine Learning Framework for Phishing Detection Using Multi-Domain Feature Analysis.
Dostupné na: https://www.researchgate.net/publication/396303070_A_Hybrid_Heuristic-Machine_Learning_Framework_for_Phishing_Detection_Using_Multi-Domain_Feature_Analysis